

POST-EXPLOITATION & CREDENTIAL EXTRACTION

TESTER
Solomon Waikumi

PROJECT
XYZ Corp Security Audit

TOOLING
Python & Mimikatz

OBJECTIVE STATEMENT

This engagement focused on automating credential theft attacks to evaluate Windows security controls. The primary objective was to extract plaintext passwords and NTLM hashes from memory using a custom Python wrapper for the Mimikatz framework.

TECHNICAL METHODOLOGY

- 1. Verification:** The script validates the presence of the Mimikatz binary on the filesystem before execution.
- 2. Escalation:** Utilizes `privilege::debug` to obtain the necessary rights to interact with the Local Security Authority Subsystem Service (LSASS).
- 3. Extraction:** Executes `sekurlsa::logonpasswords` to dump credentials directly from memory.
- 4. Auditing:** Implements a logging mechanism to record execution details, ensuring compliance with audit requirements.

SECURITY CONTROLS & LOGGING

To maintain professional standards, every execution is logged to `mimikatz_log.txt`. This provides a clear audit trail for the client, XYZ Corp, detailing exactly when and how the extraction tool was utilized during the assessment.

FINDINGS ANALYSIS

Successful execution of this script demonstrates a critical security risk. If an attacker gains local administrative rights, they can use these automated methods to harvest credentials from memory, facilitating lateral movement across the internal network.